

Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Лабораторная работа №1

"Разработка защищенного REST API с интеграцией в CI/CD"

Выполнил:

Федоров Евгений Константинович

Группа: P3410

Санкт-Петербург,

2026

Оглавление

<i>Инициализация проекта.....</i>	<i>2</i>
<i>Описание проекта.....</i>	<i>2</i>
<i>Список эндпоинтов</i>	<i>2</i>
<i>Защита от SQL-инъекций.....</i>	<i>5</i>
<i>Защита от XSS-атак</i>	<i>5</i>
<i>Реализация аутентификации пользователя</i>	<i>5</i>

Инициализация проекта

Для данного проекта был создан репозиторий Git и был связан с репозиторием на GitHub.

Ссылка на репозиторий: https://github.com/2BuRy1/information_security_lab_1

Описание проекта

В данной работе было реализовано REST API приложение с поддержкой аутентификацией при помощи JWT-токена. У аутентифицированных пользователей есть возможность просмотра других зарегистрированных в системе пользователей, отправки им сообщений по логину и просмотра собственных сообщений.

Приложение написано на Java 17 с использованием Spring Boot (Spring Web MVC, Spring Security, Spring Data JPA), в качестве СУБД используется PostgreSQL, для сборки и запуска проверок — Maven.

Список эндпоинтов

- POST auth/register – регистрация

Формат запроса:

```
{
  "login": "alice",
  "password": "alicepass",
  "repeatedPassword": "alicepass"
}
```

Формат ответа:

```
{
  "token": "some_tome"
}
```

- POST auth/login – вход

Формат запроса:

```
{
  "login": "alice",
  "password": "alicepass",
}
```

Формат ответа:

```
{
  "token": "some_tome"
}
```

- GET api/data – получение списка зарегистрированных пользователей

Формат ответа:

```
[
  {
    "id": 53,
    "login": "bob"
  }
]
```

- POST api/messages – отправить сообщение

Формат запроса:

```
{
  "recipient": "bob",
  "text": "hey, bob!"
}
```

Формат ответа:

```
{
  "id": 1,
  "from": "alice",
  "to": "bob",
  "text": "hey, bob",
  "createdAt": "2026-09-15T21:42:48.60984"
}
```

- GET api/message – получить все сообщения

Формат ответа:

```
[
  {
    "id": 1,
    "from": "alice",
    "to": "bob",
    "text": "hey, bob",
    "createdAt": "2026-09-15T21:42:48.60984"
  }
]
```

Защита от SQL-инъекций

Защита от SQL-инъекций обеспечивается использованием Spring Data JPA поверх Hibernate. Все обращения к БД идут через методы репозитория, которые Hibernate транслирует в параметризованные подготовленные запросы (PreparedStatement) согласно спецификации JPA. Конкатенации строк при построении SQL в проекте нет ни в одном месте, пользовательские данные всегда передаются как связанные параметры, а не встраиваются в текст запроса.

Защита от XSS-атак

Приложение является чистым REST API и не генерирует HTML: все ответы отдаются в формате application/json и сериализуются библиотекой Jackson, входящей в Spring Boot. Jackson при сериализации экранирует специальные и управляющие символы (кавычки, переводы строк и т.д.) по правилам JSON. Дополнительно реализована защита при помощи экранирования специальных символов HTML средствами фреймворка.

Реализация аутентификации пользователя

В работе используется JWT access-токен. Access-токен служит для доступа к защищённым эндпоинтам: именно по нему определяется пользователь. Время жизни токена – 1 час, токен подписывается алгоритмом HS256 секретным ключом.

Токен выдаётся при регистрации POST /auth/register и при входе POST /auth/login.

На защищённых эндпоинтах стоит фильтр - он проверяет наличие и формат заголовка Authorization: Bearer <токен>, проверяет подпись и срок действия, загружает пользователя из БД и устанавливает аутентификацию.

В базе данных пароли хранятся только в виде хэшей bcrypt, сырые пароли нигде не сохраняются и не логируются.

Полученные отчеты по SAST/SCA из Actions

SAST:

```
1  ▶ Run mvn -B -ntp spotbugs:check
7  [INFO] Scanning for projects...
8  [INFO]
9  [INFO] -----< com.security:lab >-----
10 [INFO] Building lab 0.0.1-SNAPSHOT
11 [INFO]    from pom.xml
12 [INFO] -----[ jar ]-----
13 [INFO]
14 [INFO] >>> spotbugs:4.9.3.0:check (default-cli) > :spotbugs @ lab >>>
15 [INFO]
16 [INFO] --- spotbugs:4.9.3.0:spotbugs (spotbugs) @ lab ---
17 [INFO] Fork Value is true
18 [INFO] Done SpotBugs Analysis....
19 [WARNING] Unable to find a URL to the parent project. The parent menu will NOT be added.
20 [INFO] Rendering content with org.apache.maven.skins:maven-fluido-skin:jar:2.0.0-M9 skin
21 [INFO]
22 [INFO] <<< spotbugs:4.9.3.0:check (default-cli) < :spotbugs @ lab <<<
23 [INFO]
24 [INFO]
25 [INFO] --- spotbugs:4.9.3.0:check (default-cli) @ lab ---
26 [INFO] BugInstance size is 0
27 [INFO] Error size is 0
28 [INFO] No errors/warnings found
29 [INFO] -----
30 [INFO] BUILD SUCCESS
31 [INFO] -----
32 [INFO] Total time: 17.526 s
33 [INFO] Finished at: 2026-09-16T18:05:19Z
34 [INFO] -----
```

SCA:

```
1  ▶ Run mvn -B -ntp dependency-check:check -DnvdApiKey="BWD_API_KEY"
8  [INFO] Scanning for projects...
9  [INFO]
10 [INFO] -----< com.security:lab >-----
11 [INFO] Building lab 0.0.1-SNAPSHOT
12 [INFO]    from pom.xml
13 [INFO] -----[ jar ]-----
14 [INFO]
15 [INFO] --- dependency-check:12.1.0:check (default-cli) @ lab ---
16 [INFO] Checking for updates
17 [INFO] Skipping the NVD API Update as it was completed within the last 1440 minutes
18 [INFO] Skipping Known Exploited Vulnerabilities update check since last check was within 24 hours.
19 [INFO] Check for updates complete (228 ms)
20 [INFO]
21
22 Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and
23 there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the
24 use of this tool, the analysis performed, or the resulting report.
25
26 About OWC: https://jeremylong.github.io/DependencyCheck/General/Internals.html
27 False Positives: https://jeremylong.github.io/DependencyCheck/General/Suppression.html
28
29 ♥ Sponsor: https://github.com/sponsors/jeremylong
30
31 [INFO] Analysis Started
32 [INFO] Finished Archive Analyzer (0 seconds)
33 [INFO] Finished File Name Analyzer (0 seconds)
34 [INFO] Finished Jar Analyzer (0 seconds)
35 [INFO] Finished Dependency Merging Analyzer (0 seconds)
36 [INFO] Finished Minst Analyzer (0 seconds)
37 [INFO] Finished Version Filter Analyzer (0 seconds)
38 [INFO] Created CPE Index (2 seconds)
39 [INFO] Finished CPE Analyzer (4 seconds)
40 [INFO] Finished False Positive Analyzer (0 seconds)
41 [INFO] Finished NVD CVE Analyzer (0 seconds)
42 [INFO] Finished RetireJS Analyzer (0 seconds)
43 [INFO] Finished Vulnerability Suppression Analyzer (0 seconds)
44 [INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds)
45 [INFO] Finished Dependency Bundling Analyzer (0 seconds)
46 [INFO] Finished Unused Suppression Rule Analyzer (0 seconds)
47 [INFO] Analysis Complete (17 seconds)
48 [INFO] Writing HTML report to: /home/runner/work/information_security_lab_1/information_security_lab_1/lab/target/dependency-check-report.html
49 [INFO] Writing JSON report to: /home/runner/work/information_security_lab_1/information_security_lab_1/lab/target/dependency-check-report.json
50 [INFO]
51 [INFO] BUILD SUCCESS
52 [INFO]
53 [INFO] Total time: 15.561 s
54 [INFO] Finished at: 2026-09-16T18:05:36Z
55 [INFO] -----
```

Ссылка на последний запуск pipeline в репозитории:

https://github.com/2BuRy1/information_security_lab_1/actions/runs/35137409008/job/104933114454